ENTERPRISE BEHAVIORAL SECURITY INTELLIGENCE PLATFORM (ITBIS)

AI-Powered Insider Threat Detection & Behavioral Intelligence

Complete Full-Stack Engineering & Forensic Defense Architecture

An end-to-end security operations platform featuring hybrid anomaly detection (Heuristic Rules + Unsupervised Isolation Forest), dynamic 5-factor risk scoring, automated forensic incident synthesis, role-based executive dashboards, and in-memory export engines.

PROJECT CANDIDATE & IMPLEMENTATION METADATA:

Done by: Sritha — Final Year Aspiring Student

Architecture: FastAPI (Python 3.14) • Next.js 14 App Router • Scikit-Learn Isolation Forest • Dual Storage (SQLite itbis.db & MongoDB) • ReportLab & OpenPyXL

Milestone Status: Milestones 1, 2, 3 & 4 (Executive Dashboards & Reporting) Built, Tested & Verified (100% Test Pass)

THE THREAT LANDSCAPE

The Problem: Why Traditional Firewalls Fail Against Insiders

PERIMETER BLINDNESS

1. The Perimeter Blindspot

• Traditional perimeter defenses (Firewalls, VPNs, WAFs) monitor north-south ingress/egress from external IP addresses.

• Malicious insiders and stolen credentials bypass 100% of perimeter rules because traffic originates from trusted, authenticated sessions.

• **82% of enterprise breaches involve authorized user credentials or legitimate privileges abused from within (Verizon DBIR).**

• Firewalls cannot distinguish between an authorized employee generating a routine database report and an employee exfiltrating records.

INFORMATION OVERLOAD

2. Log Explosion & Alert Fatigue

• Modern enterprise infrastructures generate hundreds of gigabytes of raw logs daily (Active Directory, Kerberos, SSH, file shares).

• Traditional SIEM systems rely on static threshold alerts (e.g. 'flag if transfer > 500 MB').

• Static thresholds yield **>90% false alarms**, drowning SOC engineers in alert fatigue while stealthy attackers stay under thresholds.

• Without contextual behavioral baselines, insider exfiltration remains undetected for an average of **287 days**.

INSIDER RISK REALITY

3. The Disgruntled Insider Profile

• Flight-risk employees, resigning staff, and compromised accounts systematically stage corporate data prior to departure.

• Attackers leverage low-and-slow data movement, off-hours access, and alternative protocols (SFTP, USB mounts, cloud sync).

• Static rules fail to spot contextual deviation—such as an engineer suddenly reading payroll databases at 2:00 AM.

• Solution: Continuous behavioral profiling, peer-group benchmarking, and automated digital forensic timelines.

PROJECT ARCHITECTURE

Platform Roadmap & Scope: Milestones 1 Through 4

MILESTONE 1: DAYS 1–10

Milestone 1: Foundations

- Role-Based Access Control: 4 distinct roles (Admin, Security Manager, Security Analyst, SOC Engineer).
- Stateless JWT Auth: OAuth2 Bearer tokens with 12-round bcrypt password hashing.
- Employee Directory: Tracks identity, department, designation, devices, and baseline risk.
- SQLite Persistence: Normalized schema with SQLAlchemy 2.0 ORM models.

MILESTONE 2: DAYS 11–20

Milestone 2: Ingestion & AI

- Document Telemetry: MongoDB JSON backing store for high-throughput event capture.
- Heuristic Engine: Deterministic rules catching off-hours logins, volume spikes, and USB mounts.
- Unsupervised ML: Scikit-Learn Isolation Forest with contamination factor c=0.12.
- Feature Engineering: Extracts login hour, transfer volume, and failure velocity.

MILESTONE 3: DAYS 21–30

Milestone 3: UEBA & Forensics

- 5-Factor Risk Scorer: Standardized weighted composite risk equation (0 to 100).
- Peer Group UEBA: Statistical Z-score benchmarking against department peers.
- Investigation Workbench: Stitched linear chronological telemetry timelines.
- Forensic Evidence Ledger: Digital evidence tracking and MITRE ATT&CK; framework mapping.

MILESTONE 4: DAYS 31–34

Milestone 4: Dashboards & Exports

- Manager Compliance View: Resolution rate % and open critical triage.
- Accurate MTTR & MTTI: Tracks incident lifecycle and investigation start times.
- Admin Health Analytics: Workforce coverage and platform anomaly rates.
- In-Memory Exports: ReportLab PDF dossiers and bulk Excel (.xlsx) workbooks.

FULL-STACK PIPELINE

End-to-End System Architecture & High-Throughput Data Flow

DATA FLOW BREAKDOWN

Data Pipeline & Service Architecture

- **1. Client Presentation Layer (Next.js 14):**
- Browser communicates with backend via Axios REST API with JWT authorization headers.
- **2. REST Application Gateway (FastAPI):**
- Starlette async engine, Pydantic data validation, and Depends(require_role(...)) guards.
- **3. Telemetry Ingestion Engine:**
- High-throughput ingestion of login, file, USB, and network telemetry into document store.
- **4. Dual Analytical Processing:**
- Simultaneous evaluation by Heuristic Rules and Scikit-Learn Isolation Forest.
- **5. Dynamic 5-Factor Risk Calculator:**
- Synthesizes rule, ML, peer Z-score, role, and privilege sub-scores.
- **6. Automated Incident & Forensic Synthesizer:**
- Generates incident dossiers, MITRE T1048 mapping, and evidence ledger.
- **7. Dual Storage Tier:**
- ACID relational persistence in SQLite (itbis.db) + Document Store in MongoDB.

ENGINEERING STANDARDS

Key Architectural Invariants

- **Stateless Authentication: Zero session state maintained on server; JWT claims validated cryptographically per request.**
- **Least-Privilege RBAC: Explicit role checking (Admin, Security Manager, Security Analyst, SOC Engineer) enforced at router level.**
- **Dual-Database Strategy: Strict relational integrity for compliance entities; flexible schema document store for high-volume logs.**
- **In-Memory Export Generation: PDF and Excel streams constructed entirely in RAM (io.BytesIO) to eliminate disk collisions.**
- **Real-Time Event Correlator: Anomaly events linked directly to employee identities and stitched into chronological timelines.**
- **Defensive Error Boundaries: Division-by-zero guards on empty databases and None-safe date formatting on un-resolved records.**

ENGINEERING CHOICES

Technology Stack Breakdown & Architectural Rationale

APPLICATION GATEWAY

Backend: FastAPI (Python 3.14)

- Asynchronous Non-Blocking I/O: Starlette + Uvicorn delivers microsecond REST latencies for high-throughput log ingestion.
- Pydantic V2 Type Safety: Automated schema validation, serializing, and self-documenting Swagger/OpenAPI docs at /docs.
- SQLAlchemy 2.0 ORM: Thread-safe relational abstraction with connection pooling and declarative models.
- Dependency Injection Security: Custom require_role(...) dependencies enforce RBAC natively before handler execution.
- Native Machine Learning Interop: Direct in-process execution of Scikit-Learn without IPC latency.

USER INTERFACE

Frontend: Next.js 14 & Tailwind

- React 18 & App Router: Server and client components with route caching and optimized hydration.
- Tailwind Dark Obsidian UI: Cyber-themed interface designed for low eye-strain in 24/7 SOC environments.
- Lucide Icons & Chart.js: Interactive radar charts, risk distribution visualizers, and 7-day anomaly trend graphs.
- Axios Request Interceptors: Automated JWT header attachment, unified error boundaries, and blob download streaming.
- Client-Side Role Switching: Instant evaluation testing across all 4 RBAC personas in live demo.

INTELLIGENCE & DATA

AI & Data: Isolation Forest & Reports

- Scikit-Learn Isolation Forest: Fast recursive partitioning efficient for high-dimensional outlier detection.
- ReportLab Platypus: In-memory dynamic PDF compiler producing executive dossiers via io.BytesIO() without disk writes.
- Pandas & OpenPyXL: High-speed tabular workbook generator with safe date formatting and custom column sorting.
- Dual-Database Strategy: Relational tables for accounts/incidents; document store for unstructured telemetry.

DATA STORAGE LAYER

Dual-Database Architecture: Relational SQLite vs NoSQL MongoDB

RELATIONAL ACID STORE

Relational Store: SQLite / PostgreSQL (itbis.db)

- Role: ACID transaction integrity, relational joins, foreign keys, and audit compliance.
- users: id, email, password_hash, full_name, role, is_active, created_at.
- employees: id, employee_id, name, department, designation, device_info, access_privileges, status, baseline_risk_score.
- incidents: id, incident_code, employee_id, severity, status, title, description, assigned_to, mitre_attack_technique, investigation_started_at, resolved_at.
- evidence: id, incident_id, note, added_by (User ID), added_at (foreign key linked).
- alerts: id, alert_code, employee_id, severity, message, status, anomaly_type, risk_score, created_at, resolved_at.
- audit_logs: id, user_id, user_email, action, target_resource, details, timestamp.

HIGH-VOLUME DOCUMENT STORE

Document Store: MongoDB / JSON Collections (data/)

- Role: High-throughput ingestion of un-structured event streams and anomaly records.
- activity_logs.json: Raw audit telemetry events with timestamp, employee_id, event_type (LOGIN, FILE_TRANSFER, USB_MOUNT), bytes_transferred, ip_address, and status.
- rule_anomalies.json: Deterministic violations flagged by rule engine with detected_at, severity, rule_name, and employee_id.
- ml_anomalies.json: Statistical anomaly entries with is_anomaly (boolean), anomaly_score (float), and feature vectors.
- Aggregation Pipeline Support: Uses $match, $group, and $dateToString for 7-day anomaly trend visualizations and department-level aggregations.

AUDIT & INGESTION

Telemetry Ingestion Pipeline & Platform Audit Logging

LOG INGESTION ENGINE

High-Throughput Log Ingestion Pipeline

- **Endpoint: POST /api/logs/ingest**
- Validates event schema via Pydantic ActivityLogIngest model.
- **Supported Telemetry Types:**
- • LOGIN: IP address, user agent, workstation hostname, login hour.
- • FILE_ACCESS / FILE_TRANSFER: Source folder, file size, bytes.
- • PRIVILEGE_USE: Sudo, admin impersonation, token generation.
- • USB_DEVICE: Mass storage insertion, device serial.
- **Automatic Timestamping: Fallback to UTC if client timestamp missing.**
- **Non-Blocking Persistence: Thread-safe in-memory cache synchronized with JSON backing store.**

GOVERNANCE AUDIT TRAIL

Day 32 Simple Audit Log Implementation

- **Dedicated Helper Function: log_action(db, user_id, action, details, target_resource)**
- **Retrofitted Across Sensitive Security Endpoints:**
- 1. Alert Assignment: /api/alerts/{id}/assign -> logs assignee email and assigner user_id.
- 2. Alert Resolution: /api/alerts/{id}/resolve -> logs resolving analyst and timestamp.
- 3. Incident Creation: /api/incidents -> logs newly generated incident code and target employee.
- 4. Status Updates: /api/incidents/{id}/status -> tracks transitions from OPEN to INVESTIGATING or RESOLVED.
- 5. User Provisioning: /api/auth/register -> records new account creation and granted RBAC role.
- **Queryable API: GET /api/dashboard/admin/audit-log and exportable to Excel.**

BEHAVIORAL RULE ENGINE

Detection Engine 1: Deterministic Heuristic Policy Rules

TEMPORAL ANOMALY

Rule 1: Off-Hours Access

- Trigger: Employee logs in or accesses resources between 22:00 and 05:00 local time.
- Context: Checked against department working hours profile.
- Severity: HIGH.
- Threat Rationale: Disgruntled staff frequently stage exfiltration during night shifts when physical SOC staffing is minimal.

DATA EXFILTRATION

Rule 2: Volume Spike

- Trigger: Single-session file transfer exceeds 1.0 GB or 3.5x normal baseline volume.
- Context: Evaluated against 30-day historical transfer rolling average.
- Severity: CRITICAL.
- Threat Rationale: Mass downloading of source code repositories or sensitive financial exports.

PRIVILEGE ABUSE

Rule 3: Restricted Access

- Trigger: Access attempt on classified folders (e.g., /prod/finance_db_backup).
- Context: Cross-referenced with employee access_privileges list.
- Severity: CRITICAL.
- Threat Rationale: Snooping, lateral movement, or privilege abuse across departmental boundaries.

HEURISTIC ESCALATION

Rule 4: Multi-Alert Spike

- Trigger: More than 3 distinct rule triggers within a rolling 60-minute window.
- Context: Aggregated by employee_id.
- Severity: CRITICAL.
- Threat Rationale: Active, aggressive exfiltration campaign requiring immediate automated quarantine.

MACHINE LEARNING

Detection Engine 2: Unsupervised Machine Learning (Isolation Forest)

ML ENGINE CORE

Algorithm Architecture & Feature Engineering

• **Why Isolation Forest? Traditional clustering (K-Means, DBSCAN) struggles with high-dimensional sparsity. Isolation Forest isolates anomalies recursively: outliers require fewer random splits to separate.**

• **Trained on 3 Engineered Behavioral Features:**

• 1. Login Hour Metric: Normalizes access time (0.0 to 23.99).

• 2. Data Volume Transferred: Megabytes moved per operation.

• 3. Access Failure Velocity: Number of 401/403 errors in session.

• **Contamination Factor: Configured to c = 0.12 (12%), matching enterprise SOC anomaly expectations.**

• **Mathematical Anomaly Score:**

• s(x, n) = 2^(-E(h(x)) / c(n))

• Where E(h(x)) is average path length across 100 decision trees.

SCORING & DECISION

Inference, Decision Boundary & Normalization

• **Model Output & Scikit-Learn Prediction:**

• • Prediction = -1 -> Behavioral Anomaly Flagged.

• • Prediction = +1 -> Normal In-Distribution Activity.

• **Score Normalization: Raw decision function scores [-0.5, 0.5] mapped linearly to standard [0.0, 1.0] confidence interval.**

• **Zero-Day Threat Detection: Catches multi-dimensional deviations that evade single-variable rule thresholds (e.g., moderate volume transfer paired with unusual hours and elevated failure rate).**

• **Model Persistence: Automatically re-fits and updates dynamic baselines as healthy workforce telemetry accumulates.**

RISK INTELLIGENCE

Dynamic 5-Factor Risk Scoring Engine & UEBA Benchmarking

MATHEMATICAL MODELING

The 5-Factor Composite Mathematical Formula

- **Composite Risk Equation:**
- Risk Score = 0.35 * R_rule + 0.30 * R_ML + 0.20 * R_peer + 0.10 * R_role + 0.05 * R_priv
- **1. Rule Violations (35% Weight): Cumulative severity of deterministic triggers.**
- **2. Machine Learning Anomaly (30% Weight): Isolation Forest anomaly probability score.**
- **3. Peer Group Deviation (20% Weight): Statistical Z-score deviation from departmental mean:**
- Z = (Employee_Activity - Mean_Dept) / StdDev_Dept
- **4. Role Sensitivity (10% Weight): Intrinsic sensitivity of role (Finance/DevOps = 85, Sales = 40).**
- **5. Privilege Factor (5% Weight): Access level score (K8s/Prod DB = 90, Standard = 30).**

RISK STRATIFICATION

Risk Stratification & SOC Action Thresholds

- **Score Normalization Range: 0.0 to 100.0**
- **1. LOW RISK (Score 0 – 24): Normal baseline operation. No analyst action needed.**
- **2. MEDIUM RISK (Score 25 – 49): Mild anomaly or minor off-hours login. Telemetry logged; system continues passive monitoring.**
- **3. HIGH RISK (Score 50 – 74): Elevated behavioral outlier. Alert dispatched to SOC Analyst queue; single-click incident creation available.**
- **4. CRITICAL RISK (Score 75 – 100): High-confidence malicious insider event. Automated incident generated; immediate credential quarantine recommended.**

CASE STUDY

Live Threat Simulation: Case Study of Devon Miller (EMP1003)

BASELINE INTEGRITY

Phase 1: Healthy Baseline State

- **Subject: Devon Miller (EMP1003)**
- **Department: Cloud Infrastructure / DevOps**
- **Role: Senior Cloud Infrastructure Lead**
- **Initial Baseline Risk Score: 15.2 (Low)**
- **Initial Status: ACTIVE**
- **Normal Behavior: Standard working hours (09:00 - 18:00), average transfer volume < 45 MB, zero policy violations.**

THREAT SIMULATION

Phase 2: Attack Simulation Trigger

- **Attack Scenario: 'mass_exfiltration'**
- **Simulation API: POST /api/simulation/run**
- **Payload: {'scenario': 'mass_exfiltration', 'employee_id': 'EMP1003'}**
- **Injected Telemetry Events:**
- • 02:45 AM: Off-hours SSH session opened.
- • 02:50 AM: 8.4 GB sensitive financial backups exported via SFTP.
- • 02:52 AM: Unauthorized token access on /prod/finance_db_backup.

THREAT NEUTRALIZATION

Phase 3: Real-Time AI Detection

- **Risk Score Jump: 15.2 -> 84.6 (CRITICAL RED ALERT).**
- **UEBA Peer Deviation: Delta = +84.6 above Cloud Ops team mean.**
- **Rule Triggers: Off-hours access + mass transfer spike.**
- **ML Isolation Forest: Anomaly score s = 0.912 (Severe Outlier).**
- **Incident Generated: INC-2026-8841 automatically opened and assigned to SOC triage.**

SOC FORENSICS

Incident Investigation Workbench & Forensic Evidence Ledger

FORENSIC WORKBENCH

Investigation Workbench Features

• **Incident Dossier Generation: POST /api/incidents/{id}/generate-ai-report**

• Automated AI Forensic Brief synthesizing employee profile, event context, and containment playbooks.

• **Chronological Event Timeline: Stitches raw MongoDB activity logs and anomaly triggers into an interactive linear timeline.**

• **MITRE ATT&CK; Mapping:**

• • T1048.002: Exfiltration Over Alternative Protocol (SSH/SFTP).

• • T1078.004: Valid Accounts: Cloud Accounts.

• • T1083: File and Directory Discovery.

• **Recommended SOC Playbooks: Revoke Kerberos session, isolate laptop MAC, notify HR and Legal.**

CHAIN OF CUSTODY

Digital Evidence Chain of Custody

• **Relational Table: evidence (linked to incidents via foreign key).**

• **Stored Fields: id, incident_id, note, added_by (User ID), added_at (UTC).**

• **Live Forensic Evidence Captured for EMP1003:**

• • EVID-1092: Mass exfiltration of 8.4 GB financial backup files via SFTP at 02:50 UTC.

• • EVID-1093: Isolation Forest peer group deviation exceeded 4.8 standard deviations.

• • EVID-1094: Unauthorized token generation attempt on production financial database.

• **Immutable Tracking: Analyst attribution logged with tamper-evident audit trail.**

MANAGEMENT & HEALTH

Executive & Admin Dashboards (Milestone 4 Days 31 & 32)

EXECUTIVE COMPLIANCE

Day 31: Security Manager Compliance View

- **Endpoint: GET /api/dashboard/manager/compliance**
- **Allowed Roles: admin, security_manager (403 for analysts).**
- **Resolution Rate Calculation:**
- Rate % = round((resolved_incidents / total_incidents) * 100, 1)
- **Zero-Division Guard: Defaults safely to 0.0% on empty database.**
- **Separate Open Critical Metric: Highlights unresolved critical threats regardless of overall percentage.**
- **MTTR (Mean Time to Respond): Average hours between alert created_at and resolved_at.**
- **MTTI (Mean Time to Investigate): Average hours between incident creation and an analyst beginning triage (investigation_started_at).**

PLATFORM GOVERNANCE

Day 32: Admin Dashboard & Platform Health

- **Endpoint: GET /api/dashboard/admin (Strict admin only).**
- **User Governance: Aggregates accounts by role (admin, security_manager, security_analyst, soc_engineer).**
- **Monitored Workforce: Employees tracked & distinct departments count via db.query(Employee.department).distinct().count().**
- **Platform Volume Analytics: GET /api/dashboard/admin/platform-analytics**
- **Calculates Platform Anomaly Rate:**
- Anomaly Rate % = round(((rule_anomalies + ml_anomalies) / total_logs) * 100, 2)
- **Sanity Metric: Verifies detection sensitivity (real-world SOCs aim for single-digit anomaly rates; flags over-tuning).**

REPORTING ENGINE

Reports & Export System: In-Memory PDF & Excel (Days 33 & 34)

PDF ENGINE (REPORTLAB)

Day 33: In-Memory PDF Reporting Engine

• Built with ReportLab Platypus & io.BytesIO() entirely in RAM.

• **Zero Temporary Disk Writes: Eliminates server disk accumulation, race conditions, and unneeded disk I/O.**

• **1. Individual Risk Report: GET /api/reports/{employee_id}/pdf**

• • Styled 5-factor sub-score table (#7a1f2b crimson header).

• • Capped at 10 recent anomalies; handles 0 total cleanly without crashing.

• **2. Compliance Summary Report: GET /api/reports/compliance/pdf**

• • Reuses Day 31 compliance metrics, SLA benchmarks, and incident audit records.

• **Headers: Content-Disposition: attachment; filename=... with media_type='application/pdf'.**

EXCEL EXPORTS & CATALOG

Day 34: Excel Data Exports & Report Catalog

• Built with Pandas & OpenPyXL for structured tabular datasets.

• **MIME Type: application/vnd.openxmlformats-officedocument.spreadsheetml.sheet**

• **1. Bulk Risk Scores: GET /api/reports/export/risk-scores**

• • Pre-sorted descending: highest-risk staff appear first.

• • Optional department filter parameter.

• **2. Incident Export: GET /api/reports/export/incidents**

• • Inline date guard: i.resolved_at.strftime(...) if i.resolved_at else 'Not resolved' prevents AttributeError.

• **3. Report Catalog: GET /api/reports/catalog**

• • Single source of truth serving UI with available formats and endpoints.

QUALITY ASSURANCE

Verification, Testing & Automated Quality Assurance

TEST AUTOMATION

Automated TestClient Suite

• Executed in test_milestone4_endpoints.py.

• **100% Pass Rate across all Milestone 4 test suites:**

• • Day 31 Compliance View & MTTR/MTTI calculations.

• • Day 32 Admin user counts & platform volume analytics.

• • Audit logging across alert assignment, resolution, and incident creation.

• • PDF generation for both high-anomaly and zero-anomaly employees.

• • Excel risk sorting and unresolved date handling.

EDGE-CASE RESILIENCE

Defensive Edge-Case Handling

• **Division-by-Zero Guards: Ensured resolution rate and anomaly rate endpoints never crash on fresh empty databases.**

• **None-Safe Date Formatting: Unresolved incidents gracefully display 'Not resolved' instead of throwing 500 errors.**

• **RAM Buffer Rewind: Enforced buffer.seek(0) across all PDF and Excel streams to eliminate corrupted downloads.**

• **Static Route Precedence: Placed /reports/compliance/pdf before dynamic /reports/{employee_id}/pdf.**

RBAC SECURITY

Security & RBAC Enforcement

• **Role Isolation Verified: Non-admin roles (analyst, soc_engineer, manager) correctly receive 403 Forbidden on admin dashboard.**

• **JWT Signature Verification: Cryptographically validates token expiry and subject IDs.**

• **Bcrypt Salted Hashes: 12-round salted hashing protects passwords against rainbow table lookups.**

• **Audit Immutability: Administrative and security actions logged with operator email and timestamp.**

PROJECT SUMMARY & DEMONSTRATION COMPLETE

Thank You!

Done by Sritha — Final Year Aspiring Student

AI-Powered Insider Threat Detection and Behavioral Security Intelligence Platform (ITBIS) Complete Full-Stack Implementation: Milestones 1, 2, 3 & 4 (Executive Dashboards & Reporting)

LIVE DEPLOYMENT & TESTING REFERENCE:

- **Live Application UI:** http://localhost:3000 | **FastAPI Gateway & Swagger Docs:** http://127.0.0.1:8000/docs
- **Git Remote Branch:** origin/student-sritha | **Database Store:** SQLite (backend/itbis.db) & MongoDB (backend/data/)
- **Demo Credentials: admin@itbis.security / manager@itbis.security / analyst@itbis.security (Password: Security@123)**